

Guia LGPD para o escritório pequeno

O que guardar, onde, por quanto tempo, quem acessa, e o
que nunca colar em IA pública. Bônus do kit.

Um escritório de advocacia guarda mais dado pessoal do que a maioria das empresas do mesmo tamanho: documentos, extratos, laudos, conversas, fotos de RG. A Lei Geral de Proteção de Dados (Lei 13.709/2018) vale para o escritório de um advogado só do mesmo jeito que vale para o grande. Este guia é o mínimo prático para um escritório de 1 a 4 pessoas: saber o que guarda, onde, por quanto tempo, quem acessa, o que nunca colar em uma IA pública e o que fazer se algo vazar.

O que este guia não é. Não é parecer, não garante conformidade com a LGPD e não substitui a análise de quem cuida do jurídico do próprio escritório (que pode ser você mesmo, com outro chapéu, ou um colega que atua na área). Ele organiza a casa para que essa análise seja rápida. Onde houver dúvida sobre base legal, prazo de guarda ou comunicação de incidente, a decisão é jurídica e é sua.

1. Por que isso importa para um escritório pequeno

Três motivos, do mais frequente ao mais grave:

- **Cliente pergunta.** Empresas que contratam o escritório cada vez mais perguntam "como vocês guardam os nossos dados?". Responder com uma página pronta fecha a proposta; responder "no meu computador" trava.
 - **Celular perdido, e-mail invadido, estagiário que saiu com acesso.** É o incidente comum. Sem mapa do que existe e onde, você não sabe nem o que foi exposto.
 - **Sigilo profissional e LGPD andam juntos.** O Estatuto da Advocacia já obriga ao sigilo; a LGPD acrescenta deveres de organização, minimização, segurança e resposta a incidente. Um reforça o outro.
-

2. O que o escritório guarda (inventário)

Preencha a tabela abaixo uma vez e revise a cada seis meses. É o "mapa de dados" simplificado; sem ele, nada do resto funciona. A coluna "Sensível" segue a lista da LGPD (saúde, origem racial, religião, opinião política, vida sexual, dado genético ou biométrico, entre outros): trate com cuidado redobrado.

TIPO DE DADO	EXEMPLOS	DE QUEM	SENSÍVEL?	ONDE FICA (SEÇÃO 3)
Identificação	nome, CPF, RG, CNH, endereço, telefone, e-mail	clientes, partes, testemunhas	não	pasta do caso, cadastro
Financeiro	extratos, holerites, comprovantes, dados bancários, valor de honorários	clientes	não, mas confidencial	pasta do caso, Planilhas 13 e 14
Documentos do caso	contratos, petições, provas, fotos, áudios, conversas de WhatsApp	clientes, terceiros	às vezes	pasta do caso
Saúde	laudos, atestados, prontuários (comum em previdenciário, trabalhista, família)	clientes, dependentes	sim	pasta do caso
Família e menores	certidões, dados de filhos, guarda	clientes, menores	sim (menores)	pasta do caso
Equipe	dados de estagiários, associados, contador	equipe	às vezes (saúde)	pasta administrativa
Contatos e captação	nome e telefone de quem pediu orçamento, seguidores, lista de e-mail	possíveis clientes	não	celular, e-mail, planilha 15
Dados das planilhas do kit	nome do cliente, valores, datas, horas	clientes (indiretamente)	não	pasta de gestão

Regra prática de minimização: se o dado não é necessário para o caso ou para a cobrança, não peça. Foto do RG serve; cópia do RG dos filhos do cliente, quando não são parte, não.

3. Onde fica cada coisa

O problema do escritório pequeno não é o servidor; é o dado espalhado. Faça a lista real, sem vergonha:

LUGAR	O QUE COSTUMAR	RISCO PRINCIPAL	MÍNIMO A FAZER
Computador do escritório	pastas de casos, planilhas	roubo, defeito sem backup	senha de login, disco criptografado (BitLocker/FileVault), backup
Notebook e celular pessoal do sócio	tudo, misturado com a vida pessoal	perda, filho que usa, app que lê o disco	bloqueio de tela, criptografia, apagamento remoto ativado
WhatsApp	documentos, áudios, fotos de RG, conversas	backup automático na nuvem pessoal, grupo errado	número do escritório separado, backup na nuvem desligado ou criptografado, apagar mídia depois de salvar na pasta
E-mail	anexos de anos, senha antiga	invasão, encaminhamento errado	autenticação em dois fatores, senha única, não usar o e-mail como arquivo
Nuvem (Drive, OneDrive, Dropbox)	pasta de casos	link "qualquer pessoa com o link", conta pessoal	conta do escritório, compartilhamento por pessoa, revisão de links
Papel	procurações, documentos originais, anotações	armário aberto, lixo comum	armário com chave, fragmentadora, protocolo de devolução
Sistemas de terceiros (tribunal, checkout, contador)	dados que você entregou	vazamento deles	saber quais são e ter o contato de cada um
Ferramentas de IA	o que alguém colocou lá	retenção pelo fornecedor, uso para treino	seção 6

Recomendação de estrutura mínima: **uma pasta por caso**, com nome padronizado (**cliente-assunto-aaaa-mm**), dentro de uma conta de nuvem do escritório (não do sócio), com subpastas fixas: **01-contrato**, **02-documentos-do-cliente**, **03-processo**, **04-financeiro**, **05-encerramento**. Tudo que chega pelo WhatsApp vai para lá no mesmo dia e sai do celular.

4. Por quanto tempo guardar

Aqui a decisão é jurídica: prazos de prescrição, de guarda de documentos fiscais e de obrigações do contrato variam com a área e com o caso. O guia não fixa os prazos; ele obriga você a fixá-los e anotar. Preencha com quem cuida do jurídico do escritório e com o contador:

CONJUNTO	PRAZO DEFINIDO PELO ESCRITÓRIO	QUEM DEFINIU	DATA
Documentos do caso após o encerramento	[] anos		
Contratos de honorários e comprovantes de pagamento	[] anos		
Documentos fiscais (notas, guias)	[] anos (pergunte ao contador)		
Dados de quem pediu orçamento e não contratou	[] meses		
Conversas de WhatsApp com clientes	[] (após salvar na pasta)		
Backups	[] versões / meses		

Três regras que não dependem de prazo:

1. **Anote a data de encerramento** de cada caso na Planilha 4. Sem ela, o relógio não começa.
2. **Apagar é apagar.** Lixeira da nuvem, backup antigo e o celular do sócio precisam entrar na rotina de descarte. Papel vai para a fragmentadora, não para o lixo.
3. **Quando o prazo chega, alguém decide.** Uma tarefa "revisar descarte" por trimestre na Agenda de prazos (Planilha 1), como tarefa interna, resolve.

5. Quem acessa o quê

Escritório de 1 a 4 pessoas costuma ter todo mundo com acesso a tudo. É cômodo e é o maior risco. Regra simples:

PESSOA	ACESSA	NÃO ACESSA
Sócios	tudo do escritório	conta pessoal um do outro
Advogado associado	casos em que atua	financeiro do escritório, casos dos outros
Estagiário	casos em que auxilia, com pasta compartilhada por pessoa	financeiro, pasta administrativa, senhas do escritório
Contador	resumo do mês, notas, extratos, retiradas	conteúdo dos casos, Carteira completa
Secretaria ou atendimento	agenda, cadastro básico, cobrança	documentos do caso, saúde, menores

Checklist de acesso:

- ☐ Cada pessoa tem o próprio login (nada de senha compartilhada por WhatsApp).
- ☐ Autenticação em dois fatores no e-mail, na nuvem e no WhatsApp de todo mundo.
- ☐ Quando alguém sai, o acesso é cortado no mesmo dia: e-mail, nuvem, grupos, sistemas, chave.

- ☐ Compartilhamento na nuvem é por pessoa, nunca por "qualquer pessoa com o link".
- ☐ Um termo simples de confidencialidade assinado por estagiário e associado (o seu modelo).
- ☐ Revisão de acessos a cada seis meses, junto com o inventário da seção 2.

6. O que nunca colar em uma IA pública

IA pública é qualquer ferramenta em que você digita e a resposta vem de um servidor de terceiro (ChatGPT, Gemini, Copilot, Claude e outras, especialmente nas versões gratuitas ou pessoais). O que entra pode ser guardado pelo fornecedor, revisado por pessoas e, em alguns planos, usado para treinar modelos. Sigilo profissional e LGPD não param na porta da ferramenta.

Nunca:

- nome, CPF, CNPJ, RG, endereço, telefone ou e-mail de cliente, parte, testemunha ou colega;
- número real de processo (ele identifica as partes em um clique);
- qualquer trecho de petição, contrato, laudo, prova, decisão ou conversa com o cliente;
- foto, áudio ou vídeo de documento;
- dado sensível de qualquer pessoa, mesmo sem nome (o contexto identifica);
- dado de equipe (salário, atestado, avaliação) com nome.

Pode, com cuidado:

- números de gestão sem identificação: valores, horas, datas, categorias, "Cliente A", "Processo 1" (é assim que os 40 prompts do kit funcionam);
- textos seus, administrativos, sem dado de terceiro (rotina, pauta, mensagem padrão);
- perguntas gerais de gestão, planilha e escrita.

Como anonimizar em 30 segundos: copie o bloco da planilha para um texto, troque a coluna Cliente por letras (A, B, C), apague a coluna do número do processo, leia uma vez procurando nome próprio ou número. Se o texto continua identificando alguém pelo contexto ("o único restaurante que atendemos"), troque o contexto também.

Se o escritório decidir usar IA com dados reais, isso exige um plano empresarial com contrato de tratamento de dados, retenção zero e o "de acordo" de quem cuida do jurídico. Enquanto não tiver, a regra é a de cima. E escreva a regra: uma linha no termo de confidencialidade da equipe resolve ("é proibido inserir dado de cliente em ferramenta de IA sem autorização do sócio").

7. Mínimo de segurança que cabe em uma tarde

Não é tudo o que se pode fazer; é o que um escritório pequeno consegue fazer sem contratar ninguém, em ordem de retorno:

1. **Dois fatores em tudo** (e-mail, nuvem, WhatsApp, banco, sistemas de tribunal): 40 minutos.

2. **Gerenciador de senhas** para a equipe, com uma senha diferente por serviço: 1 hora.
3. **Criptografia de disco** ligada nos computadores e bloqueio de tela em 2 minutos: 20 minutos.
4. **Backup automático** da pasta de casos em um segundo lugar (nuvem do escritório + disco externo guardado em local diferente), com teste de restauração a cada trimestre: 1 hora.
5. **WhatsApp do escritório** em número separado, com verificação em duas etapas e backup na nuvem desligado (ou criptografado): 30 minutos.
6. **Atualizações automáticas** do sistema e do navegador: 10 minutos.
7. **Um e-mail de teste de golpe** para a equipe a cada seis meses, para ninguém clicar em "seu processo foi atualizado, veja o anexo": 20 minutos.

8. Se algo vazar: o que fazer nas primeiras 48 horas

Vazamento é qualquer situação em que dado pessoal foi visto, copiado, perdido ou ficou acessível por quem não devia: celular perdido, e-mail enviado para a pessoa errada, link aberto na nuvem, invasão de conta, papel esquecido no fórum. Não é hora de julgar; é hora de agir na ordem:

1. **Conter (hora 0).** Bloquear o aparelho ou apagar remotamente; trocar a senha e derrubar as sessões abertas; fechar o link; pedir ao destinatário errado que apague e confirme por escrito.
2. **Registrar (hora 1).** Em um documento com data e hora: o que aconteceu, quando foi descoberto, quais dados e de quantas pessoas, quem teve acesso, o que foi feito. Esse registro é obrigatório na prática e vai ser pedido depois.
3. **Avaliar (dia 1).** Com quem cuida do jurídico do escritório: há risco ou dano relevante para as pessoas afetadas (dado sensível, financeiro, de menor, volume grande)? Essa avaliação decide o passo 4.
4. **Comunicar (prazo definido na avaliação).** A LGPD prevê comunicação à ANPD e aos titulares quando o incidente pode acarretar risco ou dano relevante, em prazo razoável definido pela autoridade (consulte a regulamentação vigente da ANPD na data do incidente). Quem decide se comunica, o que e quando é a análise jurídica, não este guia. Cliente afetado costuma preferir saber por você antes de saber por outro caminho.
5. **Corrigir (semana 1).** O que permitiu o incidente (senha fraca, link aberto, celular sem bloqueio) entra na lista da seção 7 e é resolvido antes de qualquer outra coisa.
6. **Aprender (mês 1).** Uma linha no registro de incidentes do escritório (basta uma planilha com data, o que foi, quantas pessoas, o que mudou) e o assunto entra na revisão semestral.

Tenha à mão, antes de precisar: telefone da operadora do celular, contato do suporte da nuvem e do e-mail, contato do contador, e o nome de quem cuida do jurídico do escritório.

9. Modelo simples de aviso de privacidade para o site do escritório

Use como ponto de partida. Troque os colchetes, apague o que não se aplica e peça a revisão de quem cuida do jurídico do escritório antes de publicar. Publique em uma página própria (/privacidade) e aponte para ela no rodapé, no formulário de contato e no e-mail de boas-vindas.

Aviso de privacidade · [Nome do escritório]
Última atualização: [data]

Quem somos. [Nome do escritório], inscrito na OAB/[UF] sob o nº [], com endereço em [], é o responsável pelo tratamento dos dados pessoais descritos aqui. Contato para assuntos de privacidade: [e-mail].

Quais dados tratamos. (a) Dados de contato que você nos envia pelo site, WhatsApp ou e-mail (nome, telefone, e-mail, assunto). (b) Dados necessários à prestação dos serviços contratados, que podem incluir documentos pessoais, financeiros e, quando o caso exigir, dados sensíveis, como informações de saúde. (c) Dados de navegação coletados por cookies, se você consentir.

Para que usamos. Responder ao seu contato; prestar os serviços jurídicos contratados e cumprir obrigações legais e regulatórias da advocacia; emitir cobranças e documentos fiscais; manter registros pelo prazo exigido; e, se você autorizar, enviar comunicações do escritório.

Base legal. Tratamos os dados com fundamento na execução do contrato, no cumprimento de obrigação legal, no exercício regular de direitos e, quando aplicável, no seu consentimento, que pode ser retirado a qualquer momento.

Com quem compartilhamos. Apenas com quem precisa para a prestação do serviço: órgãos do Poder Judiciário e administrativos, contador do escritório, provedores de tecnologia (armazenamento em nuvem, e-mail, meio de pagamento) e, quando necessário, outros profissionais envolvidos no caso. Não vendemos dados. Não inserimos dados de clientes em ferramentas de inteligência artificial sem contrato que garanta sigilo.

Por quanto tempo. Pelo período necessário à prestação do serviço e ao cumprimento de prazos legais e profissionais; depois, os dados são apagados ou anonimizados. Dados de quem entrou em contato e não contratou são apagados em até [] meses.

Seus direitos. Confirmação, acesso, correção, anonimização, portabilidade, informação sobre compartilhamento, revogação do consentimento e eliminação, nos limites da lei e do sigilo profissional. Para exercê-los, escreva para [e-mail]. Respondemos em até [15] dias.

Segurança. Adotamos medidas técnicas e administrativas para proteger seus dados, como controle de acesso, autenticação em dois fatores, criptografia e cópias de segurança.

Cookies. [Este site usa apenas cookies necessários ao funcionamento. / Este site usa cookies de estatística e de anúncios mediante o seu consentimento; você pode gerenciá-los em [link].]

Alterações. Este aviso pode ser atualizado; a data acima indica a versão vigente.

10. Checklist de dez minutos (a cada seis meses)

- ☐ Inventário da seção 2 revisado; nada novo espalhado.
- ☐ Nenhum link "qualquer pessoa com o link" aberto na nuvem.
- ☐ Todo mundo com dois fatores ativos; ninguém que saiu ainda com acesso.
- ☐ Backup testado: restaurei um arquivo de um caso encerrado.
- ☐ Casos encerrados há mais tempo que o prazo da seção 4 foram descartados e a data anotada.
- ☐ WhatsApp do escritório sem documento pendente de mover para a pasta.
- ☐ Nenhum prompt de IA usado no semestre continha nome ou número real (perguntar à equipe).
- ☐ Aviso de privacidade do site com data de atualização recente e contato válido.
- ☐ Registro de incidentes lido; ações do último incidente concluídas.
- ☐ Data da próxima revisão marcada na Agenda de prazos como tarefa interna.

Este guia é um ponto de partida de gestão. Não promete conformidade: conformidade é resultado de análise jurídica, de rotina e de revisão. Quem cuida do jurídico do escritório deve validar cada decisão marcada como "definida pelo escritório".

Suporte: suporte@seusociogestor.com.br · Reembolso em até 7 dias.